

RETEST ETHICAL HACKING

Proyecto: DT.Claro.Miniprogram.TuLlave_Mass | Fecha: 21/05/2026

Target API: <https://urs.qa.vettica.co> | Total hallazgos: 16
Crítica: 2 | Alta: 3 | Media: 5 | Baja: 6
Priorizacion: 16 hallazgos — 2 críticos
- Priorizar remediación de hallazgos CRITICAL (secretos, inyección, auth rota).
- Planificar corrección de hallazgos HIGH (transporte, headers, exposición).
Extensiones analizadas: .acss, .axml, .js, .json

Endpoints analizados

#	Metodo	Path	Hallazgos
1	GET	/card/valid/	0
2	GET	/card/getBalance/	0
3	GET	/card/getInformation/	0

Vulnerabilidad	Riesgo	CVSS	Estado	Endpoint
Hardcoded Credentials	CRITICAL	9.0	Persistente	https://urs.qa.vettica.co
Servidor acepta JWT con alg=none (firma bypasseada)	CRITICAL	9.0	Persistente	https://urs.qa.vettica.co/
[Semgrep] detected-jwt-token	HIGH	8.0	Persistente	https://urs.qa.vettica.co
[Semgrep] detected-jwt-token	HIGH	8.0	Persistente	https://urs.qa.vettica.co
[Semgrep] detected-jwt-token	HIGH	8.0	Persistente	https://urs.qa.vettica.co
Insecure HTTP Endpoint	MEDIUM	6.0	Persistente	http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCA
Insecure HTTP Endpoint	MEDIUM	6.0	Persistente	http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCA
Sensitive Data in Logs	MEDIUM	6.0	Persistente	https://urs.qa.vettica.co
Falta cabecera Strict-Transport-Security (HSTS)	MEDIUM	6.0	Persistente	https://urs.qa.vettica.co
JWT TTL excesivo (2160h)	MEDIUM	6.0	Persistente	https://urs.qa.vettica.co
Falta X-Content-Type-Options	LOW	3.0	Persistente	https://urs.qa.vettica.co/
Falta Referrer-Policy	LOW	3.0	Persistente	https://urs.qa.vettica.co/
Validación manual requerida: BOLA/IDOR por objeto	LOW	3.0	Persistente	https://urs.qa.vettica.co
Validación manual requerida: BFLA por rol	LOW	3.0	Persistente	https://urs.qa.vettica.co
Validación manual requerida: Mass Assignment	LOW	3.0	Persistente	https://urs.qa.vettica.co
Validación manual requerida: JWT claims/TTL/revocación	LOW	3.0	Persistente	https://urs.qa.vettica.co

Detalle tecnico

1. Hardcoded Credentials (CRITICAL)

Estado: Persistente | CWE: CWE-798
Endpoint: <https://urs.qa.vettica.co>
Descripcion: Coincidencia de patrón HARDCODED_CREDENTIALS en main/ui/pages/pseForm/pseForm.js:222.
Recomendacion: No almacenes contraseñas en código; usa gestores de secretos.

2. Servidor acepta JWT con alg=none (firma bypasada) (CRITICAL)

Estado: Persistente | CWE: CWE-345

Endpoint: <https://urs.qa.vettica.co/>

Descripción: El endpoint <https://urs.qa.vettica.co/> respondió 404 a un token forjado con alg=none. Cualquier usuario puede suplantar a otro sin conocer la clave secreta.

Recomendación: Valida alg en allowlist estricta (['HS256', 'RS256']). Rechaza alg: none explícitamente.

3. [Semgrep] detected-jwt-token (HIGH)

Estado: Persistente | CWE: CWE-321: USE OF HARD-CODED CRYPTOGRAPHIC KEY

Endpoint: https://urs.qa.vettica.co

Descripción: JWT token detected

Recomendación: Corregir según la regla Semgrep indicada; revisar documentación del lenguaje y OWASP.

4. [Semgrep] detected-jwt-token (HIGH)

Estado: Persistente | CWE: CWE-321: USE OF HARD-CODED CRYPTOGRAPHIC KEY

Endpoint: https://urs.qa.vettica.co

Descripción: JWT token detected

Recomendación: Corregir según la regla Semgrep indicada; revisar documentación del lenguaje y OWASP.

5. [Semgrep] detected-jwt-token (HIGH)

Estado: Persistente | CWE: CWE-321: USE OF HARD-CODED CRYPTOGRAPHIC KEY

Endpoint: https://urs.qa.vettica.co

Descripción: JWT token detected

Recomendación: Corregir según la regla Semgrep indicada; revisar documentación del lenguaje y OWASP.

6. Insecure HTTP Endpoint (MEDIUM)

Estado: Persistente | CWE: CWE-319

Endpoint: <http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCAMR01?wsdl>

Descripción: Coincidencia de patrón INSECURE_HTTP en test/getStatusViewModel.test.js:15.

Recomendación: Usa <https://> para APIs en producción y fuerza redirección HTTP→HTTPS.

7. Insecure HTTP Endpoint (MEDIUM)

Estado: Persistente | CWE: CWE-319

Endpoint: <http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCAMR01?wsdl>

Descripción: Coincidencia de patrón INSECURE_HTTP en test/validCardViewModel.test.js:16.

Recomendación: Usa <https://> para APIs en producción y fuerza redirección HTTP→HTTPS.

8. Sensitive Data in Logs (MEDIUM)

Estado: Persistente | CWE: CWE-532

Endpoint: https://urs.qa.vettica.co

Descripción: Coincidencia de patrón SENSITIVE_DATA_LOGGING en main/ui/pages/rechargeAmount/rechargeAmount.js:194.

Recomendación: No registres contraseñas ni tokens; usa enmascaramiento o niveles de log seguros.

9. Falta cabecera Strict-Transport-Security (HSTS) (MEDIUM)

Estado: Persistente | CWE: CWE-319

Endpoint: https://urs.qa.vettica.co

Descripción: No se detectó HSTS en la respuesta; los clientes no reciben la política de forzar HTTPS.

Recomendación: Añade HSTS con un max-age adecuado (y preload si aplica) en el balanceador o API gateway.

10. JWT TTL excesivo (2160h) (MEDIUM)

Estado: Persistente | CWE: CWE-613

Endpoint: <https://urs.qa.vettica.co>

Descripción: El token tiene una vida útil de 2160 horas, superior al límite recomendado de 24h.

Recomendación: Usa access tokens de vida corta ($\leq 1h$) y refresh tokens separados con rotación.

11. Falta X-Content-Type-Options (LOW)

Estado: Persistente | CWE: CWE-16

Endpoint: <https://urs.qa.vettica.co/>

Descripción: La respuesta no incluye X-Content-Type-Options: nosniff.

Recomendación: Agrega X-Content-Type-Options: nosniff en API gateway/backend.

12. Falta Referrer-Policy (LOW)

Estado: Persistente | CWE: CWE-16

Endpoint: <https://urs.qa.vettica.co/>

Descripción: No se encontró cabecera Referrer-Policy en la respuesta del API.

Recomendación: Configura Referrer-Policy estricta (p. ej., no-referrer).

13. Validación manual requerida: BOLA/IDOR por objeto (LOW)

Estado: Persistente | CWE: CWE-639

Endpoint: <https://urs.qa.vettica.co>

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Ejecuta pruebas con dos identidades y cruza IDs para detectar acceso indebido a recursos de terceros.

14. Validación manual requerida: BFLA por rol (LOW)

Estado: Persistente | CWE: CWE-285

Endpoint: <https://urs.qa.vettica.co>

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Prueba endpoints de privilegio alto con cuentas de menor rol y verifica denegación consistente.

15. Validación manual requerida: Mass Assignment (LOW)

Estado: Persistente | CWE: CWE-915

Endpoint: <https://urs.qa.vettica.co>

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Intenta campos no permitidos en payloads (role, status, flags internos) y valida whitelists server-side.

16. Validación manual requerida: JWT claims/TTL/revocación (LOW)

Estado: Persistente | CWE: CWE-613

Endpoint: <https://urs.qa.vettica.co>

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Verifica exp/iat/nbf/aud/iss/jti, rotación de claves y revocación de tokens.